VERSION 1

PCI – AWS Landing Zone

High Level Design

Prepared by: Julio Marquez | 22 December 2025

pci PHARMA SERVICES

Contents

1. DOCUMENT OVERVIEW 2
   1.1. Project Background 3
   1.2. Document Purpose 3
   1.3. Workload-Dependent Design Decisions 3
2. CURRENT STATE OF AWS ENVIRONMENT 3
   2.1. Organization and governance 4
   2.2. Identity and Access Management – AWS Identity Center 6
   2.3. Security Posture 8
   2.4. Networking – Current state in Networking Account 8
   2.5. Shared Services account – Dev Tools 9
   2.6. Workload Accounts 10
   2.7. AWS Accounts Summary Table 10
3. SOLUTION OVERVIEW 11
   3.1. What is an AWS Landing Zone? 12
   3.2. Core Components 12
   3.3. Logical Architecture 12
   3.4. Multi-account Architecture 13
   3.5. AWS Landing Zone – Organisational Units 15
   3.6. AWS Landing Zone – Core Accounts 16
   3.7. AWS Landing Zone – Primary AWS Services 17
4. DEPLOYMENT APPROACH 18
   4.1. Landing Zone Accelerator (LZA) 19
   4.2. Landing Zone Accelerator – Config Files 19
   4.3. Landing Zone Accelerator – Deployment 19
   4.4. Account Provision 20
5. NETWORK ARCHITECTURE 23
   4.5. Hub & Spoke Topology 24
   4.6. Hub Virtual Private Cloud (VPC) 25
   4.7. Egress Design 27
   4.8. Ingress Design 28

4.9. Ingress & Egress Traffic Flows 29
4.10.. Target-State Network Design Integrated with the Current Environment 30
5. SECURITY 32
5.1. IAM Identity Center 33
5.2. AWS Web Application Firewall 36
5.3. AWS Network Firewall 37
5.4. AWS Security Hub 37
6. TAGGING STRATEGY 39
6.1. Recommended tags by AWS 40
6.2. Tagging Enforcement 41
6.3. Mandatory and Recommended Tagging Model 42
7. COST MANAGEMENT 43
7.1. Consolidated Billing 44
7.2. Cost Governance, Budgets and Alerts Approach 44
8. ESTIMATED COSTS FOR LANDING ZONE RESOURCES 45

Version Control

Date	Version	Changed By	Reason for Change
22/12/2025	0.1	Julio Marquez	Initial Draft
08/01/2026	1.0	Julio Marquez	First version to publish to PCI

Circulation List

Name	Organisation/Title
Kristi Lecher	PCI / Executive Director, Digital Platforms, Data & AI
Ken Collins	PCI / Lead Architect
Sabari Mopidevi	PCI / Director, Data Engineering
Shoaib Sarwar	Version 1 / Delivery Principal
Rukaya Ogazi-Khan	Version 1 / Tech Principal
Shane Mitchell	Version 1 / Tech Principal

Reference Documents

Document Title	Description	Owner
TBC	TBC	TBC

1. DOCUMENT OVERVIEW

1.1. Project Background

PCI is a world leading Contract Development and Manufacturing Organization (CDMO), providing sterile and high potent drug development, clinical trial services, and commercial packaging for the pharmaceutical sector, from development, through commercialization and beyond. PCI's vision statement is to relentlessly strive to deliver better health outcomes for patients by combining their experience and expertise in science, manufacturing, and technology with pristine customer service.

PCI Pharma is committed to transforming its fragmented data ecosystem into a unified, enterprise-wide asset that drives agility, compliance and operational excellence. Today, crucial data is trapped in siloed systems such as Oracle JDE and MasterControl. These are connected by ad-hoc point-to-point integrations that are difficult to govern, maintain and scale. This current setup leads to inconsistent reporting, slower operations and multiple "versions of the truth" emerging due to the absence of centralized data governance and standardized data definitions.

To achieve this strategic data vision PCI and Version 1 are developing a cloud-based data platform utilizing AWS and Databricks. This solution will integrate data from PCI's enterprise systems within a scalable and governed architecture. To establish a robust foundation, Version 1 is designing an AWS Landing Zone in accordance with the AWS Well-Architected Framework. The Landing Zone will be developed in a scalable manner so that it can host PCI's data platform as well as future workloads PCI build in AWS.

1.2. Document Purpose

This document is intended to provide a high-level, overarching view of the AWS Landing Zone solution and its core components.

1.3. Workload-Dependent Design Decisions

When navigating this document, please refer to the hand icon placed throughout. This icon indicates design decisions that are intentionally left open at this High-Level Design (HLD) stage, as they are dependent upon the onboarding of specific workloads and their individual requirements. These pending decisions will be addressed during the application onboarding phase to ensure alignment with application specific requirements.

2. CURRENT STATE OF AWS ENVIRONMENT

This section provides an overview of PCI's current AWS environment, focusing on the existing organisational structure, account layout, networking configuration, security controls, and operational practices. The purpose of this assessment is to establish a clear understanding of the current state of the platform, identify architectural patterns already in use, and highlight areas that may require alignment with AWS Landing Zone best practices. The information captured in this section is based on the current configuration of the AWS Organization and its associated accounts and is intended to inform subsequent design decisions for the target landing zone architecture.

2.1. Organization and governance

The AWS environment is operating within an AWS Organizations construct, with centralized billing and account management enabled. While several elements associated with a landing zone design are present, the current organisational structure and usage patterns indicate partial adoption and opportunities for alignment with AWS best practices.

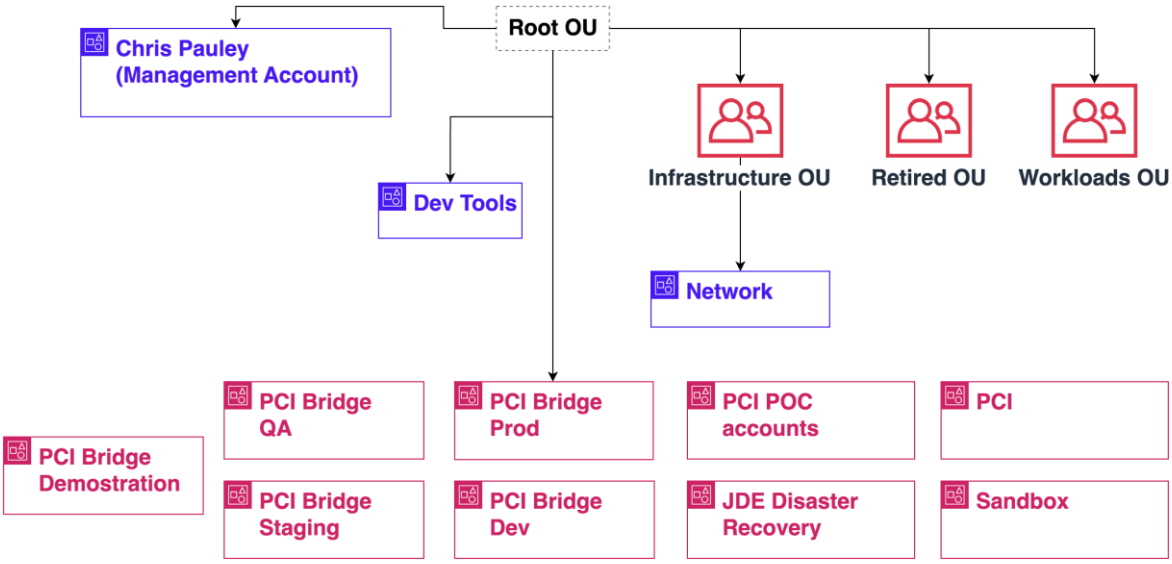


Figure 1 - Current Organisational Unit Structure

2.1.1. Organizational Structure and Accounts

The AWS Organization includes multiple accounts, some of which are currently located at the root level rather than within Organizational Units (OUs). The root account is named after an individual (Chris Pauley) and is associated with that individual's corporate email address. This introduces a dependency on a specific person for account ownership and access recovery. A similar pattern is observed in the JDE Disaster Recovery account, which is associated with a personal corporate email address belonging to another individual. It is generally recommended that AWS account root emails be tied to role-based or shared inboxes rather than personal addresses to reduce operational and access risk.

From an OU perspective, the organisation includes an Infrastructure OU containing a dedicated Networking account, as well as OUs intended for Workloads and Retired accounts. At present, the Workloads and Retired OUs are empty, and several active accounts remain positioned at the root level of the organisation rather than being grouped by function or lifecycle stage.

A Shared Services account exists and is used to host development and platform tooling such as CI/CD tools and Grafana. Additionally, multiple PCI Bridge accounts exist for different environments, following a consistent email-addressing pattern using the "plus (+)" convention to manage multiple accounts under a single mailbox, which aligns with common AWS operational practices.

2.1.2. Service Control Policies (SCPs)

Service Control Policies are enabled at the organisation level; however, only the default FullAWSAccess policy is currently applied. As a result, SCPs are not actively enforcing governance controls or preventative guardrails across accounts. This limits the organisation's ability to centrally restrict or standardise service usage, security configurations, or regional constraints.

2.1.3. Resources Usage in Management Account

The management account (Chris Pauley) contains several active resources beyond those typically expected for administrative use. In general, AWS best practices recommend that this account be reserved for organisation-wide management, billing, and governance activities only.

- **EC2 and related resources**: The account contains five EC2 instances, with only one currently running (Pulse SFTP Server). In addition, there are 37 EBS snapshots, seven EBS volumes (only one in use), 38 AMIs, and associated networking resources such as security groups, elastic IPs, and network interfaces. These resources may represent technical debt or legacy workloads and could be candidates for decommissioning or migration to more appropriate workload accounts.
- **Amazon SES**: Amazon SES is configured with multiple domain and email identities and contains a large suppression list. Approximately 4,460 emails are sent daily, apparently originating from EC2-based workloads. Hosting email-sending workloads in the management account increases operational and security risk and would typically be better suited to a dedicated workload or shared services account.
- **Amazon ECR**: Container image repositories are present in the management account. As with EC2 resources, ECR repositories used by workloads are generally

better placed in workload or shared services accounts rather than the organization account.

- **Amazon ECS**: A default ECS cluster exists with one service (coldtrack) that has no running tasks, along with three task definitions (Jenkins, coldtrack, Jenkins). This suggests legacy or inactive workloads that may no longer be required.
- **Amazon RDS**: The account holds two active RDS Reserved Instances associated with Bridge workloads, as well as multiple manual RDS snapshots. The presence of Reserved Instances in the management account may complicate cost allocation and ownership clarity.

2.1.4. AWS Support

The AWS Organization is covered by an AWS Support Business plan, providing enhanced support, architectural guidance, and faster response times for operational incidents.

2.2. Identity and Access Management – AWS Identity Center

2.2.1. Current State

The current AWS multi-account environment uses AWS IAM Identity Center (formerly AWS Single Sign-On) to centrally manage user access across multiple AWS accounts. Identity Center integrates with AWS Organizations, providing a single point from which enterprise users and groups can gain access to AWS accounts without creating long-lived IAM user credentials. IAM Identity Center creates roles and permission sets that are provisioned into each AWS account to control access based on assigned permissions.

At present, multiple user groups and permission sets exist with a mix of general, cross-account roles (e.g., Administrator, Read-only, PowerUser) and project-specific or ad-hoc permission sets (e.g., BiztalkDevsS3Access, JDEDisasterRecoveryDevelopers, ManageSES). Several IAM Identity Center groups mirror these permission sets, creating a matrix of group → permission set assignments across accounts.

AWS Control Tower creates and supports preconfigured Identity Center groups when a Landing Zone is established, intended to match permission sets to common user roles and enable consistent access patterns across accounts. User group membership in Identity Center determines the set of roles a user may assume in the AWS access portal.

Overall, the identity and access model currently functions but has evolved organically, resulting in numerous custom permission sets with varying scopes, inconsistent naming conventions, and limited documentation on permission ownership and lifecycle.

2.2.2. Alignment with AWS Best Practices

AWS documentation and best practice guidance recommend the following principles for IAM Identity Center and multi-account access management, which inform future changes and governable access patterns:

- Centralize access management via IAM Identity Center to avoid long-lived IAM user credentials and facilitate cross-account access.
- Apply the principle of least privilege when defining permission sets and assign only the minimal permissions required for each user's role.
- Use groups as the primary control point for assigning permissions, rather than individual user assignments, to improve scalability and auditability.

- Maintain consistent naming conventions and strong documentation for permission sets and associated policies to reduce risk and improve operational clarity.
- Regularly review and prune unused or overly broad permission sets to reduce attack surface and technical debt.

AWS Control Tower further encourages organizations to adopt these patterns by providing out-of-the-box guardrails and identity constructs that align with broader multi-account governance strategies.

2.2.3. Observations and Recommended Changes

The current IAM Identity Center configuration provides a solid foundation for managing user access across the AWS multi-account environment. The use of centralized identity management, group-based access assignments, and permission sets aligned to functional roles is consistent with AWS recommended practices. At a high level, no critical architectural issues have been identified in the existing access model.

However, the current structure has evolved organically over time to support multiple projects and operational needs. As a result, a deeper investigation is required to fully assess potential gaps, security improvements, and opportunities for standardisation and simplification. The following observations and recommendations are therefore considered directional and subject to further validation.

1. **Standardize Permission Set Taxonomy**

   The existing set of permission sets includes generic administrative roles and several project or application-specific sets with inconsistent naming. A standardized taxonomy aligned to enterprise role categories (e.g., Platform Admin, Security Read-only, Network Operator, Workload Developer, Production Operator) will improve clarity and reduce overlap.

2. **Strengthen Least Privilege Boundaries**

   Some broad roles such as PowerUserAccess and custom S3 permission sets may grant wider privileges than necessary for typical developer or operator tasks. A systematic least-privilege review is recommended to refine permissions and partition them into discrete, documented scopes.

3. **Audit and Rationalize Custom Roles**

   Roles such as ManageSES and project-specific S3 access suggest functional requirements that should be evaluated for consolidation or integration into a more formal role structure. Each custom set should have clearly defined owners, documented use cases, and expiration/review cycles.

4. **Improve Naming Conventions**

   Current naming does not consistently follow a pattern that conveys scope, environment, or accountability. Define a convention that includes role domain, scope, and (optionally) environment to improve manageability.

5. **User and Group Membership Review**

   A dedicated review of Identity Center users and group memberships is recommended to:

   - Identify inactive users or users who have not accessed the environment for an extended period.

- Validate that group memberships remain appropriate for current roles and responsibilities.
- Ensure that access is revoked promptly for users who no longer require it.

6. **Multi-Factor Authentication (MFA) Enforcement**

   As part of the access review, the MFA posture should be assessed to:

   - Identify users without MFA enabled.
   - Validate that MFA enforcement aligns with security policies, particularly for privileged and production access.
   - Reduce the risk associated with compromised credentials.

2.3. Security Posture

This section provides an overview of the current security posture of the AWS environment, focusing on the configuration and usage of core AWS security services, including configuration monitoring, audit logging, threat detection, and posture management. The objective is to establish a clear baseline of existing security capabilities, identify how security controls are currently applied across the AWS Organization, and highlight areas where controls are present but not yet fully standardised or centrally integrated

- **AWS Security Hub**:

  Not enabled. As a result, there is no centralised Cloud Security Posture Management layer or unified view of security findings across the organisation.

- **AWS Config**:

  Enabled and actively recording configuration data for a subset of resources. Compliance rules are present; however, no conformance packs are deployed, and there are indications of configuration recorder permission issues. Configuration data does not appear to be centrally aggregated at the organisation level.

- **AWS CloudTrail**:

  Configured with a single, regional trail that is not multi-region and not organisation-wide. This limits audit visibility and traceability across accounts and regions.

- **Amazon GuardDuty**:

  Enabled with a delegated administrator configured at the organisation level. Threat detection is active, but findings are not centrally correlated with other security signals due to the absence of Security Hub.

- **Security integration and visibility**:

  Core security services are enabled in isolation, but there is no unified security control plane or central aggregation of findings, reducing overall visibility and operational effectiveness.

2.4. Networking – Current state in Networking Account

This section describes the current networking configuration within the designated networking account, which is intended to operate as the central hub for connectivity across the AWS Organization. The assessment focuses on the use of the default VPC, Transit Gateway–based connectivity, hybrid integrations (Direct Connect and VPN), and the absence of centralised network inspection and segmentation controls.

Summary of Key Observations

- The networking account contains only the default VPC, with no custom, purpose-built hub VPC deployed. All existing subnets and network configurations belong to the default VPC.
- A single AWS Transit Gateway is in use and acts as the primary connectivity hub, with multiple workload VPC attachments (Bridge project environments, JDE), VPN connections, and Direct Connect Gateway attachments.
- The Transit Gateway is configured with one route table, with default association and propagation enabled, resulting in a largely flat routing model with limited traffic segmentation.
- Two Direct Connect connections are present. Additional VPN connections provide supplementary connectivity paths.
- No centralised network inspection controls (e.g. AWS Network Firewall or equivalent) are currently deployed.
- Default network security constructs (e.g. default network ACLs) are in place and permit broad traffic flows by default.
- ☞ Additional Direct Connect connections are present in the JDE account and are routed via the Transit Gateway in the Networking account. These connections are 1 Gbps each and, based on the Transit Gateway route table configuration, traffic is directed to different Direct Connect connections depending on destination IP ranges. This setup requires further review with PCI to clarify the intended usage, ownership, and routing rationale of these connections.

2.5. Shared Services account – Dev Tools

The Shared Services (Dev Tools) account is a centrally managed AWS account used to host common developer tooling and platform services that are shared across multiple Bridge project workload accounts. This account follows a platform-centric operating model and is responsible for providing continuous delivery, observability, and operational tooling capabilities, rather than hosting application workloads directly.

At present, the account hosts core platform tools including ArgoCD for GitOps-based application deployment and Grafana for centralised monitoring and visualisation. These tools are consumed by Bridge workload accounts to support consistent deployment practices, operational visibility, and platform standardisation across environments.

The Dev Tools account is currently located at the root level of the AWS Organization and is not placed within a dedicated Shared Services or Platform Organizational Unit (OU). As a result, it is not subject to specialised Service Control Policies (SCPs) or governance guardrails that would normally be applied to restrict tooling accounts. This limits the organisation's ability to enforce preventative controls and clearly differentiate platform accounts from workload accounts at the governance layer.

This account plays a key role in reducing duplication of tooling across workload accounts, promoting consistent deployment and observability patterns, and providing a foundation for future platform services that may be required by additional projects beyond Bridge.

2.6. Workload Accounts

The Bridge project workloads are hosted within dedicated AWS workload accounts designed to run application and platform services required by the project. These accounts follow a workload-centric operating model and are responsible for hosting application infrastructure, workload-level networking components, and service-specific security controls, while relying on the broader connectivity and governance capabilities provided at the AWS Organization level.

All Bridge workload accounts are currently located in the root Organizational Unit (OU). As a result, they are not subject to environment, or workload-specific, Service Control Policies (SCPs) or guardrails that would normally be applied through a structured OU hierarchy (e.g. non-production vs production, platform vs application). This limits the organisation's ability to enforce preventative controls, consistent security baselines, and differentiated governance across workloads.

Each workload account uses a custom VPC with public subnets, a NAT Gateway, and an Internet Gateway to support outbound and inbound application connectivity. No centralised or account-level network firewall is deployed within the workload VPCs; instead, network security controls are primarily implemented at the application edge. AWS WAF is configured and associated with Application Load Balancers and Amazon API Gateway to provide Layer 7 protection for exposed services.

The workload accounts integrate with shared foundational capabilities provided by other core accounts in the organisation. In particular, they consume developer tooling and platform services hosted within the Shared Services account, as well as centralised connectivity services provided by the Networking account (e.g. Transit Gateway, external connectivity, and hybrid networking integration).

In addition to the Bridge project, there is a separate project (JDE DR) that is hosted within a single dedicated workload account. This account is associated with Direct Connect–related costs, which require further investigation to confirm whether these charges relate to shared Direct Connect infrastructure managed by the Networking account or represent project-specific connectivity usage.

2.7. AWS Accounts Summary Table

Account Name	Current State / Findings	Recommendation
Recommended changes during Landing Zone implementation		
Management Account	Root email tied to individual.	Use shared mailbox role-based email account.
Networking Account	Default VPC only; Transit Gateway with flat routing; no network firewall; broad ACLs.	Create hub VPC; New Transit Gateway; implement segmentation; deploy AWS Network Firewall; tighten ACLs.
Recommended future enhancements to enable integration of the remaining accounts into the Landing Zone		
Shared Services (Dev Tools)	Hosts ArgoCD, Grafana; located at root OU; no SCPs applied.	Move to Shared Services OU; apply SCPs; enforce governance guardrails.
Management Account	Hosts EC2, SES, ECR, ECS, RDS workloads; IAM users with old keys and no MFA.	Migrate workloads to dedicated accounts; clean up unused resources; enforce MFA; rotate keys.
Networking Account	Transit Gateway associated to Bridge and JDE.	Integrate the remaining projects (Bridge, JDE) into the Hub-and-Spoke network.
Bridge Workload Accounts	Located at root OU; custom VPCs with public subnets; no network firewall; WAF enabled. Consistent email pattern using "+" convention; aligned with best practice.	Move to Workloads OU; apply SCPs; consider centralized firewall; review security baselines. Maintain current pattern; ensure SCPs and governance applied.
JDE Disaster Recovery	Root email tied to individual; unclear Direct Connect cost attribution.	Use role-based email; confirm Direct Connect cost ownership; move to Workloads OU.

3. SOLUTION OVERVIEW

3.1. What is an AWS Landing Zone?

An AWS Landing Zone provides a standardised, secure, and automated foundation for all your cloud workloads. It's essentially a pre-configured AWS environment that sets up multiple accounts with built-in security and compliance controls; all aligned with the AWS Well-Architected Framework. This code-first approach ensures consistent configuration and governance across PCI's entire AWS footprint.

Leveraging core AWS services such as AWS Organizations, AWS Control Tower, and AWS Config, an AWS Landing Zone will provide PCI Pharma Services with enhanced governance, control, and visibility across its AWS estate.
From a pharmaceutical and life-sciences perspective, this enables improved platform stability, availability, and security for business-critical systems, while supporting regulatory compliance, audit readiness, and controlled change management across regulated and non-regulated workloads.

3.2. Core Components

Organisation	Role
Organization Structure	Multiple Organizational Units are deployed to provide a level of governance across multiple AWS accounts
Account Breakdown	AWS recommended multi-account approach is established to isolate workloads and environments
Security	AWS security services are deployed in every account and centralized in the dedicated Security OU
Identity & Access Management	IAM Identity Center provides SSO capabilities across all AWS accounts
Account Guardrails	Service Control Policies and AWS Control Tower guardrails are applied at the OU and account levels
Hub & Spoke Topology	A Hub VPC is deployed to facilitate a *Hub & Spoke* network topology
Firewall Capability	A firewall capability is deployed to route and inspect various traffic flows across the AWS estate by way of the AWS Network Firewall service
Centralized Logging	A centralized Log and Archive account collects and aggregates platform logs from across the Landing Zone
Cost Management	Billing and cost details are centralized in the Consolidated Billing Management account for invoicing, reporting, and alerting
Account Vending	New AWS account creation is automated via the Account Factory

3.3. Logical Architecture

The diagram below illustrates a logical architecture of the AWS Landing Zone with respect to the personas – Administrators, Platform Engineers and Developers - that operate at each layer: Management, Operations & Application Development.

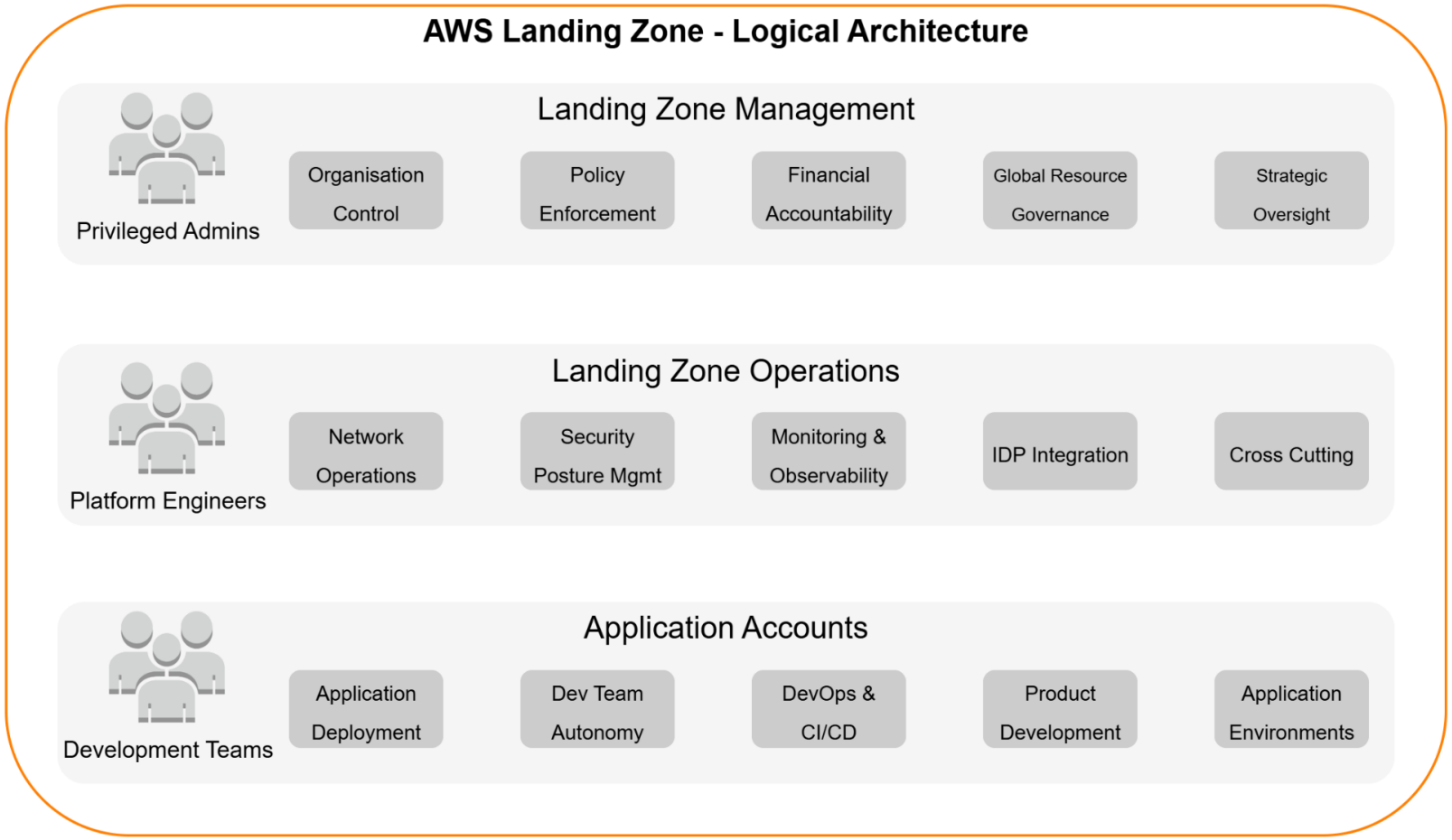


Figure 2 AWS Landing Zone - Logical Architecture

3.4. Multi-account Architecture

The following diagram illustrates the target-state architecture after the Landing Zone has been deployed and the new EDP accounts have been provisioned.

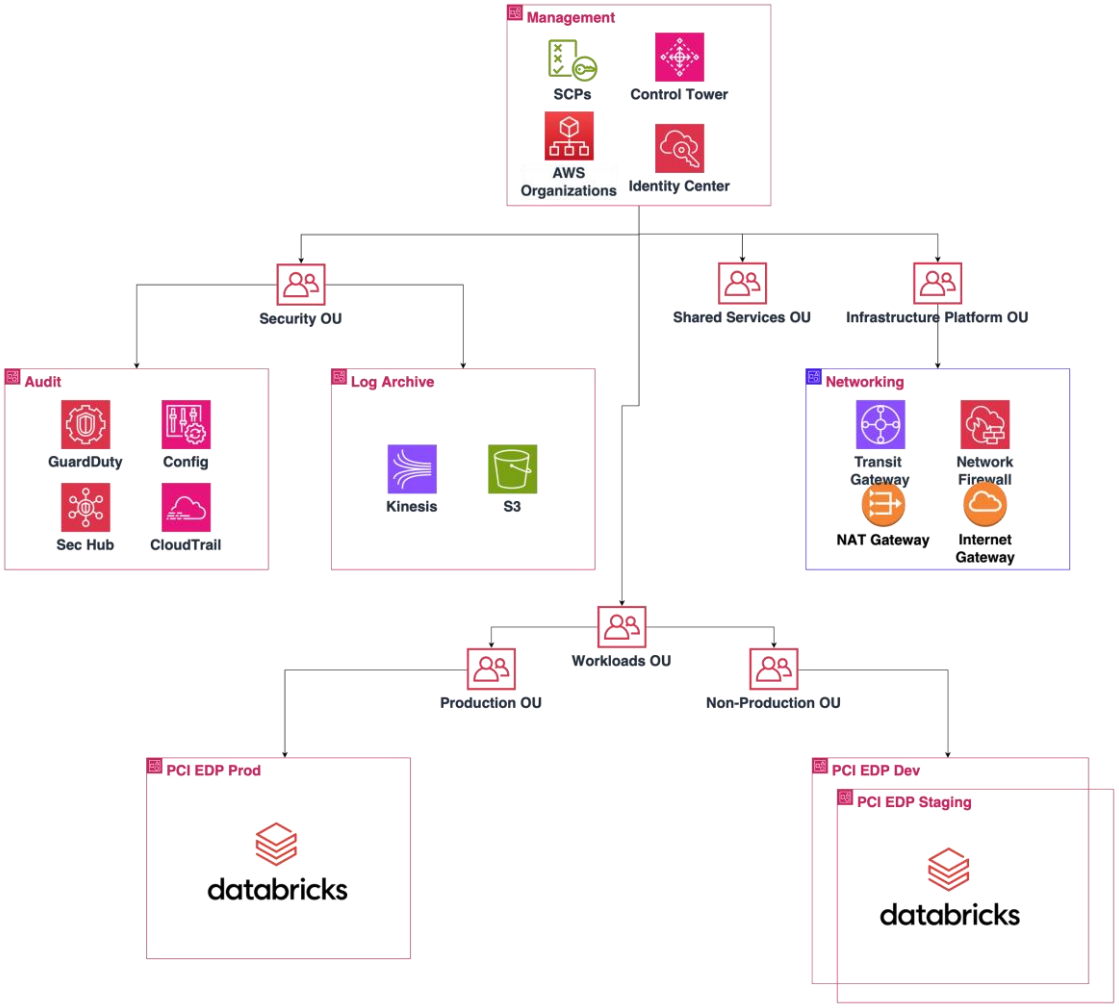


Figure 3 AWS Landing Zone - Account Hierarchy

The diagram below shows the target multi-account AWS Landing Zone hierarchy and proposed OU structure, with existing accounts included for reference only and not initially integrated into the Landing Zone.

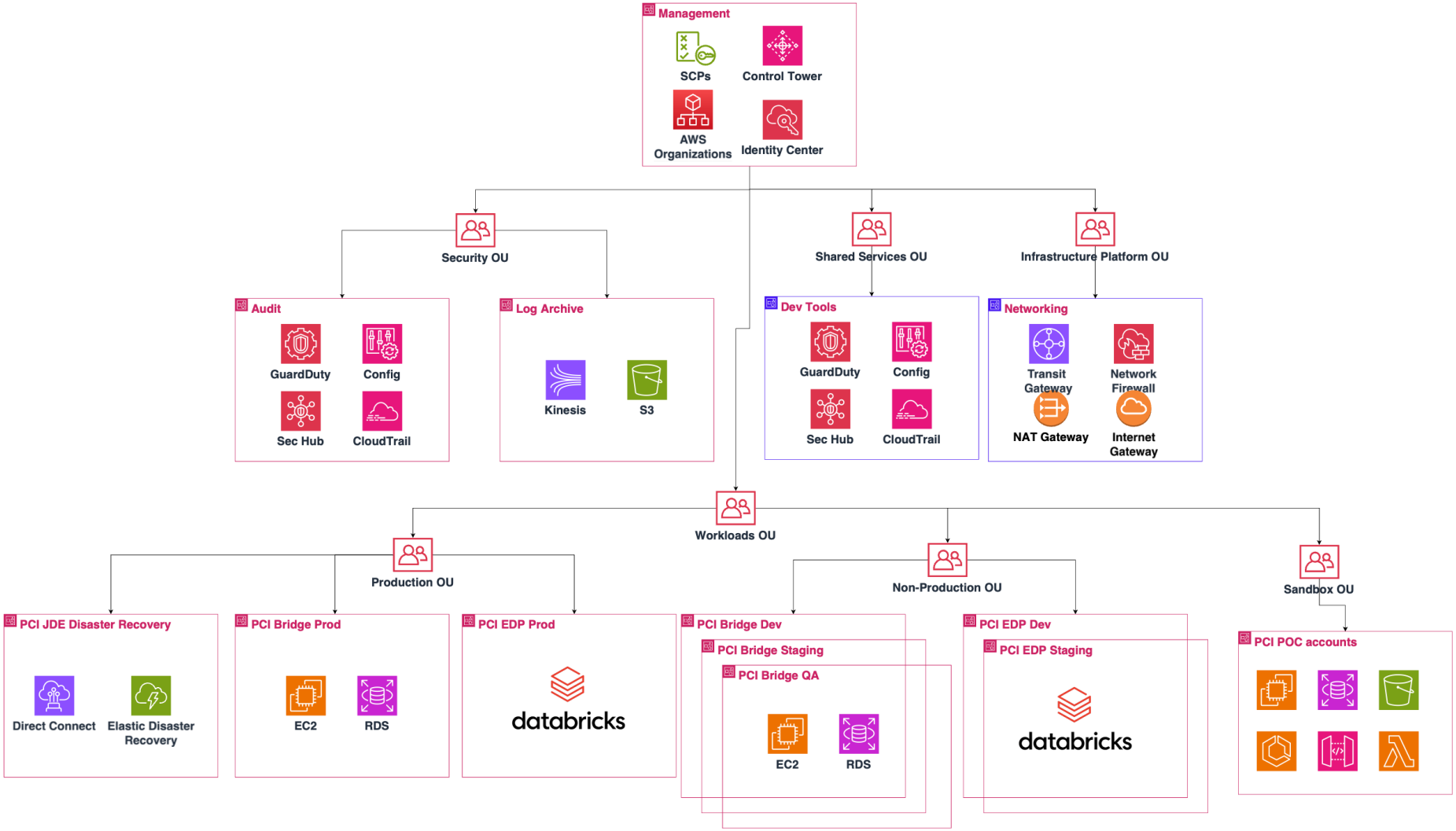


Figure 4 AWS Landing Zone - Account Hierarchy – Bridge and EDP

3.5. AWS Landing Zone – Organisational Units

An Organizational Unit (OU) in AWS is a logical grouping of AWS accounts. It acts as a container that allows organizations to group and categorise multiple AWS accounts into a hierarchical structure.

The primary purpose of OUs is to simplify the management and governance of an AWS environment by applying common policies and controls to groups of accounts. This is particularly powerful when used with Service Control Policies (SCPs), which define the maximum permissions that can be granted within accounts belonging to a particular OU.

The following table describes the OUs deployed as part of the Landing Zone solution.

OU	Role
Management	The top-level Organisational Unit, primarily containing the AWS Organisations Management account. It serves as the administrative root for the entire multi-account environment, hosting core services that manage and govern the organisation.
Security	Dedicated to centralising security services and controls. It houses accounts for security auditing (i.e., Log Archive & Audit) and incident response, ensuring compliance monitoring and unified security posture across the organisation.
Infrastructure	Designed to host shared infrastructure accounts (e.g., Network, Shared Services). This OU contains resources and services that are common dependencies for multiple workloads and are managed centrally, such as Transit Gateways, shared VPCs, or (potentially) directory services.
Workloads	A logical grouping that serves as a parent container for accounts hosting application and service environments. It provides a hierarchical structure to organise various Sandbox, Test, and Production deployments.
Production	Contains AWS accounts specifically allocated for live, mission-critical application deployments. This OU is subject to the most stringent security, operational, and change management controls to ensure stability and compliance for Production workloads.
Non-Production	Houses AWS accounts designated for development, testing, staging, and quality assurance environments. Controls here are typically more relaxed than in Production, allowing for agility in development while still maintaining a secure baseline.
AFT	An OU specifically designated for accounts provisioned and managed by AWS Control Tower's Account Factory for Terraform. It facilitates automated, customised account creation and lifecycle management through Infrastructure as Code.
Sandbox	Provides isolated AWS accounts for experimental development, proof-of-concept work, and learning. These accounts offer a high degree of autonomy to users (Developers and Engineers) but are typically subject to strict cost controls and are isolated from production environments.

3.6. AWS Landing Zone – Core Accounts

The following table describes the primary AWS accounts deployed as part of the Landing Zone solution.

Account / ID	OU	Role
Root / 080549663843	Root	This is the primary account of the AWS Organisation and the central point for billing, Service Control Policies (SCPs), and overall management of other AWS accounts. This account hosts the core Landing Zone Accelerator pipeline and automation services (CodePipeline, CodeBuild, Lambda functions) responsible for vending and governing new accounts (via AWS Control Tower's Account Factory service), as well as managing the organisational structure.
Audit / TBC	Security	A highly restricted, dedicated account for centralising all security and compliance-related logs and resources. This includes consolidating AWS Config recordings, GuardDuty findings, Security Hub aggregates, and other security service outputs from all accounts across the organisation. Access to this account is limited to security and compliance personnel only. It also integrates with AWS IAM Identity Center (formerly SSO) for centralised access management.
Log Archive / TBC	Security	A dedicated account for long-term, immutable storage of all organisational and operational logs. This includes CloudTrail logs, S3 access logs and VPC Flow Logs. Its primary purpose is secure, centralised, and immutable log retention for compliance, auditing, and troubleshooting.
Network / 975050019033	Infrastructure	Dedicated for centralising network infrastructure that spans multiple accounts across the entire organisation. This includes AWS Transit Gateway (for inter-VPC routing), centralised egress points, and shared DNS services. Consolidating networking here simplifies management and enhances security.
Shared Services / 634233678641	Shared Services	A dedicated Shared Services account used to host centralised CI/CD pipelines, monitoring and observability tooling, and other standard platform services that are consumed across multiple AWS accounts. This account provides a common operational layer, promoting consistency, reusability, and efficient governance, while avoiding duplication of tooling and enabling a clear separation between shared platform capabilities and individual workload environments.
Account Factory / TBC	AFT	A dedicated account to host services associated with account provisioning using Account Factory for Terraform (AFT). This will host the AFT related AWS CodePipeline and AWS CloudFormation Stacks that will consume the Terraform configuration and generate workload AWS accounts (AI Marking Test, AI Marking Production accounts) and any customisation configuration.

3.7. AWS Landing Zone – Primary AWS Services

The following table describes the primary AWS services deployed as part of the Landing Zone solution.

AWS Service	Role
AWS Organisations	This is the foundational service for managing multiple AWS accounts. Its facilities the consolidation and management of multiple AWS accounts under a single, unified billing and management entity. Its primary purpose is to help PCI centrally govern the AWS estate as it scales. AWS Organisations is primarily configured and managed from the Management Account.
AWS Control Tower	AWS Control Tower builds on AWS Organisations to set up and govern a secure, multi-account AWS environment i.e. the Landing Zone, according to best practices. It automates the setup of the platform's core accounts (Management, Log Archive and Audit accounts), configures guardrails (both preventative and detective), and provides a dashboard for continuous monitoring and compliance. It acts as an orchestration layer for many underlying AWS services. AWS Control Tower is deployed and managed from the Management Account. When set up, it automatically provisions the Log Archive and Audit accounts
Account Factory	The Account Factory is a feature of AWS Control Tower that automates the provisioning of new AWS accounts that are pre-configured with your organisation's established baseline (e.g., connected to AWS Organisations, enrolled in Control Tower's guardrails, pre-integrated with central logging and auditing). This ensures consistency and compliance for every new account from day one.
AWS Config	AWS Config provides a detailed inventory of your AWS resources, tracks their configuration changes over time, and evaluates these configurations against desired rules (e.g., "S3 buckets should not be publicly accessible"). AWS Control Tower automates the deployment of Config rules from the Audit account. AWS Config is enabled in each Member Account to record local resource configurations. However, to provide a layer of observability across all accounts, its findings and configuration history are aggregated centrally in the Audit account.
Service Control Policies	SCPs are a type of organisation policy that provide a mechanism for managing permissions across the AWS organisation. They provide centralised control over the maximum available permissions for all accounts in your organisation or specific Organisational Units (OUs). SCPs do not grant permissions; rather, they set guardrails by defining what actions users and roles within member accounts are *prevented* from doing, even if an IAM policy in that account explicitly grants the permission.
Identity Center	Centralises access management to all accounts within the AWS Organisation. It enables single sign-on access to AWS accounts and any applications using an existing corporate directory (e.g., Active Directory) or its own managed directory. It defines permissions at a centralised level and propagates them across the various member accounts via permission sets.
Security Hub	Provides a comprehensive view of the overall security posture across the Landing Zone. It collects security findings from various AWS services (GuardDuty, Config), aggregates them, and provides automated security checks against best practices and compliance standards.

4. DEPLOYMENT APPROACH

4.1. Landing Zone Accelerator (LZA)

The AWS Landing Zone Accelerator (LZA) is an open-source solution designed to automate the rapid deployment of a secure, scalable, and compliant multi-account AWS environment. Built upon AWS best practices and aligning with various global compliance frameworks, LZA leverages Infrastructure as Code (IaC) principles through AWS Cloud Development Kit (CDK) and a set of YAML configuration files.

It extends the foundational capabilities of AWS Control Tower by providing enhanced customisation for security controls, network topology centralised logging, auditing, and automated account provisioning. This significantly reduces the upfront manual effort in establishing a cloud foundation, enabling PCI to accelerate their cloud adoption while maintaining strict governance and security posture.

4.2. Landing Zone Accelerator – Config Files

At the heart of the AWS Landing Zone Accelerator solution are six YAML configuration files: *accounts-config.yaml, global-config.yaml, iam-config.yaml, network-config.yaml, organisation-config.yaml,* and *security-config.yaml*. These declarative files serve as the primary interface for PCI to define and customise the desired multi-account AWS environment. Therefore, the solution warrants a dedicated GitHub repository to version control these configuration files.

A new repository, **pci_aws_landing_zone_configuration**, will be created to host the LZA configuration files.

4.3. Landing Zone Accelerator – Deployment

The diagram below illustrates a high-level overview of how the PCI managed Landing Zone Configuration repository relates to the AWS components that comprise the Landing Zone solution.

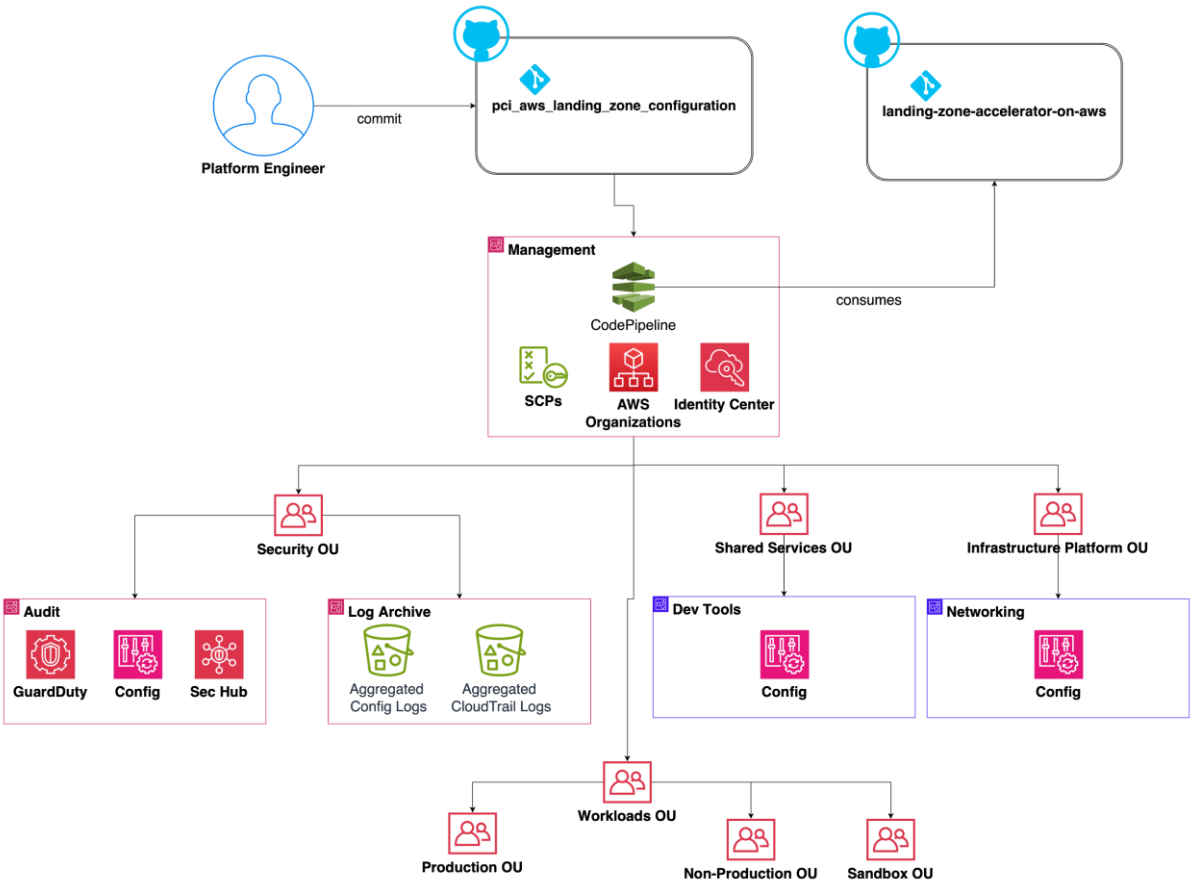


Figure 5 Landing Zone Accelerator - Deployment

4.4. Account Provision

Account provisioning describes the process by which new AWS accounts are requested, created, and prepared for use within an AWS Organization. This includes the initial account creation, placement within Organizational Units (OUs), and the application of baseline governance, security controls, and configuration standards.

Within an AWS Landing Zone based on AWS Control Tower, multiple approaches exist for provisioning accounts, each offering different levels of automation, flexibility, and operational complexity.

4.4.1. Option 1: Native Control Tower Account Factory

The native Account Factory provided by AWS Control Tower enables the creation of new AWS accounts through a managed, AWS-supported workflow. Accounts are provisioned using AWS Service Catalog products backed by AWS CloudFormation and are automatically enrolled into the landing zone with predefined guardrails, logging, and security baselines applied.

This approach offers a low-complexity and highly stable mechanism for account provisioning, making it well-suited for environments with a limited number of accounts and relatively static baseline requirements. Customisation is primarily focused on governance and security controls rather than extensive per-account infrastructure bootstrapping.

4.4.2. Option 2: AWS Control Tower with Landing Zone Accelerator

This approach builds on the native Account Factory provided by AWS Control Tower and extends it through the Landing Zone Accelerator (LZA) framework.

LZA applies additional AWS-native, CloudFormation-based standardisation after account creation, enabling consistent deployment of baseline resources—such as IAM roles, security tooling, AWS Config rules, logging, and shared infrastructure components—across accounts and Organizational Units.

These customisations are centrally defined and automatically enforced through LZA-managed pipelines, ensuring alignment with AWS best practices while avoiding the need for separate post-provisioning mechanisms such as Customizations for AWS Control Tower (CfCT).

This approach provides a balance between simplicity and automation, enabling a high degree of standardisation beyond governance controls alone, without introducing the operational overhead of fully Terraform-driven account bootstrapping. It is well suited for environments that require a consistent, centrally governed baseline while remaining aligned with AWS-native tooling.

4.4.3. Account Factory for Terraform (AFT)

Account Factory for Terraform (AFT) builds on the native Control Tower account provisioning workflow by introducing Terraform-based automation and GitOps-style pipelines for post-provisioning customisation. While accounts are still created and enrolled using AWS CloudFormation, AFT enables the deployment of complex, variable, and version controlled Terraform baselines across multiple accounts.

This approach is designed for environments with higher account creation volumes or advanced customisation requirements, where consistent Terraform-based configuration and automation are critical. However, it introduces additional architectural components and operational overhead, which may not be proportionate for environments with a limited number of accounts or relatively static baseline requirements.

4.4.4. Account Provisioning Approaches – Comparison

Option	Pros	Cons	Best Fit
Native Control Tower Account Factory	• Fully AWS-managed and supported • Lowest operational complexity • Automatic enrolment with guardrails, logging, and baseline security • Minimal ongoing maintenance	• Limited customization beyond governance controls • Not suitable for complex per-account infrastructure bootstrapping • Custom resources require separate deployment mechanisms	Low account creation volume Static baseline requirements Organisations prioritising simplicity and stability
AWS Control Tower with Landing Zone Accelerator	• Extends native Account Factory with a prescriptive AWS-supported landing zone framework • Remains fully aligned with AWS-native tooling and best practices • Enables standardised, centrally governed deployment of security, networking, logging, and baseline resources across accounts and OUs	• Limited to CloudFormation capabilities • Less flexible than Terraform for complex logic • Still requires governance of templates and lifecycle	Moderate to high account creation volume Consistent baseline across accounts Environments prioritizing AWS-native governance over custom Terraform bootstrapping
Account Factory for Terraform (AFT)	• Full Terraform and GitOps-style workflows • Highly flexible and version-controlled customizations • Scales well for large or dynamic environments	• Higher architectural and operational complexity • Additional pipelines, repositories, and state management. • Greater maintenance overhead • Potentially disproportionate for low account volumes	High account creation volume Complex, variable baselines Terraform-first operating model

5. NETWORK ARCHITECTURE

All CIDR ranges and IP address allocations referenced throughout this document are indicative and provided for design purposes only.

These ranges have not yet been validated or approved by the PCI team.

Final CIDR allocations will be requested, reviewed, and formally agreed with the PCI team during the detailed design phase to ensure alignment with the existing IP addressing strategy and to avoid any potential IP address overlap across on-premises environments, existing AWS VPCs, and future deployments.

The following sub-sections capture the high-level network architecture that has been introduced as part of the Landing Zone implementation.

4.5. Hub & Spoke Topology

To facilitate a centralized egress architecture, a Hub and Spoke network topology will be deployed. A dedicated *Hub* Virtual Private Cloud (VPC) deployed to the AWS Network account will host various network services and connect to workload specific *Spoke* VPCs hosted within AWS workload accounts.

The following list describes the network principles as they relate to this Hub & Spoke network topology

- The Hub VPC will be configured with a CIDR range of **10.100.0.0/24** providing eight /27 subnets across two Availability Zones. Since AWS withholds the first four IPs and the broadcast address (e.g. 10.100.0.255) in each subnet, this provides 27 useable IPs per subnet.
- The Network account and its Hub VPC will be dedicated exclusively to networking services (TGW endpoints, AWS Firewall, NAT Gateway), preventing the deployment of application workloads within this security-critical layer.
- The Network account will host a Transit Gateway to facilitate connectivity between Hub and Spoke VPCs, an instance of AWS Network Firewall to govern traffic flows and a NAT Gateway.
- A Transit Gateway deployed to the Network account will attach to both the Hub VPC and multiple Spoke workload VPCs in a 1-to-many manner.
- All egress (outbound) traffic originating from Spoke VPCs will be routed through the network services hosted within the Hub VPC before being routed to the Internet.
- All Spoke VPCs will be configured with a default route (0.0.0.0/0) with a next hop pointing to the Transit Gateway network interface which introduces forced tunneling requiring all internet bound traffic to be inspected.
- The Transit Gateway will route all egress traffic to the AWS Firewall service which will process (and inspect where appropriate) the traffic before forwarding to the NAT Gateway.

- The NAT Gateway provides a consistent public IP for routing all Internet bound traffic.
- Spoke VPC to Spoke VPC traffic will not be permitted unless a specific AWS Firewall policy has been configured.
- Spoke VPCs will not be directly peered or connected.

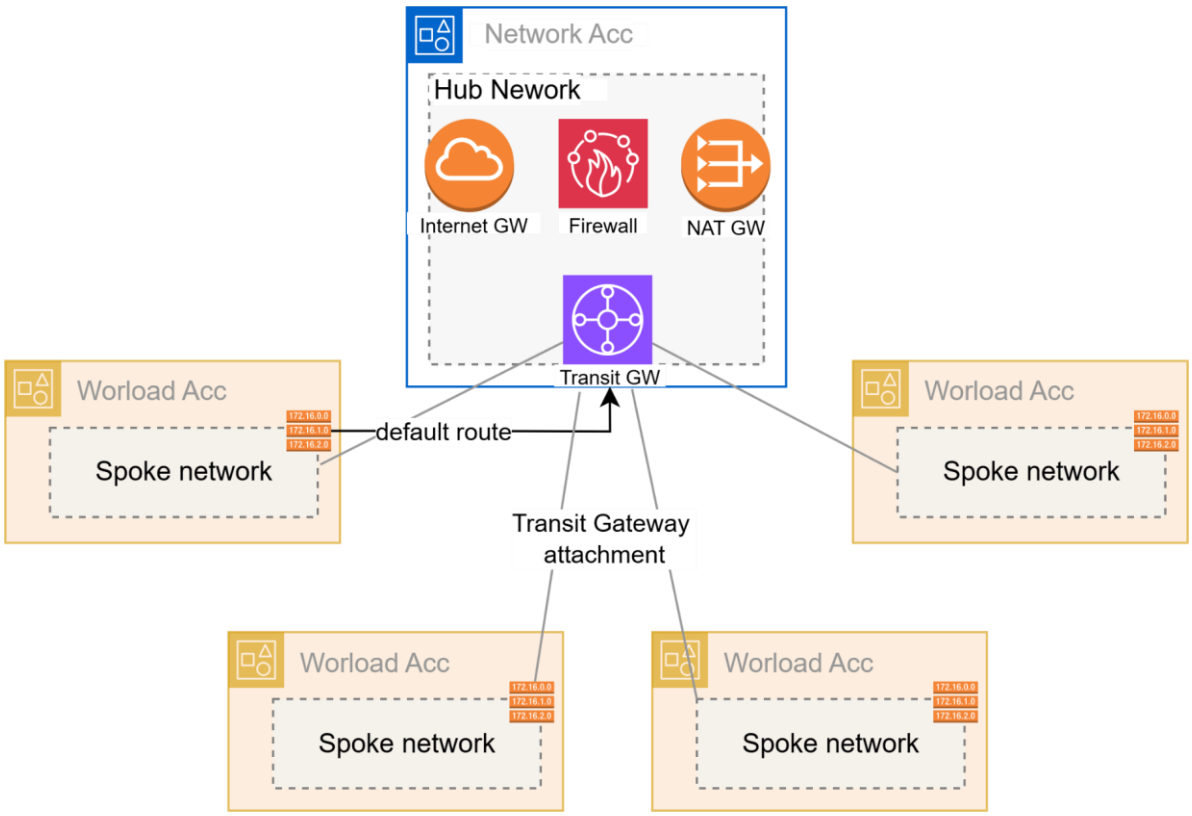


Figure 6 Hub & Spoke topology

4.6. Hub Virtual Private Cloud (VPC)

The table below provides a breakdown of the Hub's Virtual Private Cloud (VPC) from a subnet perspective.

VPC Name	Subnet Name	Subnet CIDR	AZ	Public / Private	Purpose
pci-lz-hub-vpc	pci-lz-hub-vpc/us-east-1a/nat-gw-subnet	10.100.0.0/27	1	Public	Hosts NAT Gateway endpoint
pci-lz-hub-vpc	pci-lz-hub-vpc/us-east-1b/nat-gw-subnet	10.100.0.32/27	2	Public	Hosts NAT Gateway endpoint
pci-lz-hub-vpc	pci-lz-hub-vpc/us-east-1a/network-firewall-subnet	10.100.0.64/27	1	Private	Hosts the AWS Network Firewall
pci-lz-hub-vpc	pci-lz-hub-vpc/us-east-1b/network-firewall-subnet	10.100.0.96/27	2	Private	Hosts the AWS Network Firewall
pci-lz-hub-vpc	pci-lz-hub-vpc/us-east-1a/tgw-subnet	10.100.0.128/27	1	Private	Hosts the AWS Transit Gateway
pci-lz-hub-vpc	pci-lz-hub-vpc/us-east-1b/tgw-subnet	10.100.0.160/27	2	Private	Hosts the AWS Transit Gateway
pci-lz-hub-vpc	TBC	10.100.0/192/27	1	Private	Reserved for future use.
pci-lz-hub-vpc	TBC	10.100.0.224/27	2	Private	Reserved for future use.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

The diagram below further details the Hub VPC network architecture. Initially, to optimise data transfer costs and align with anticipated low short-term traffic volumes, core network services – specifically the NAT Gateway, Transit Gateway, and Network Firewall – will be deployed within a single Availability Zone (AZ1). As the Landing Zone matures and workload onboarding increases, these critical network services will be seamlessly expanded (by way of IaC) to span two Availability Zones, thereby establishing a highly available and resilient infrastructure capable of withstanding potential disruptions to AZ1.

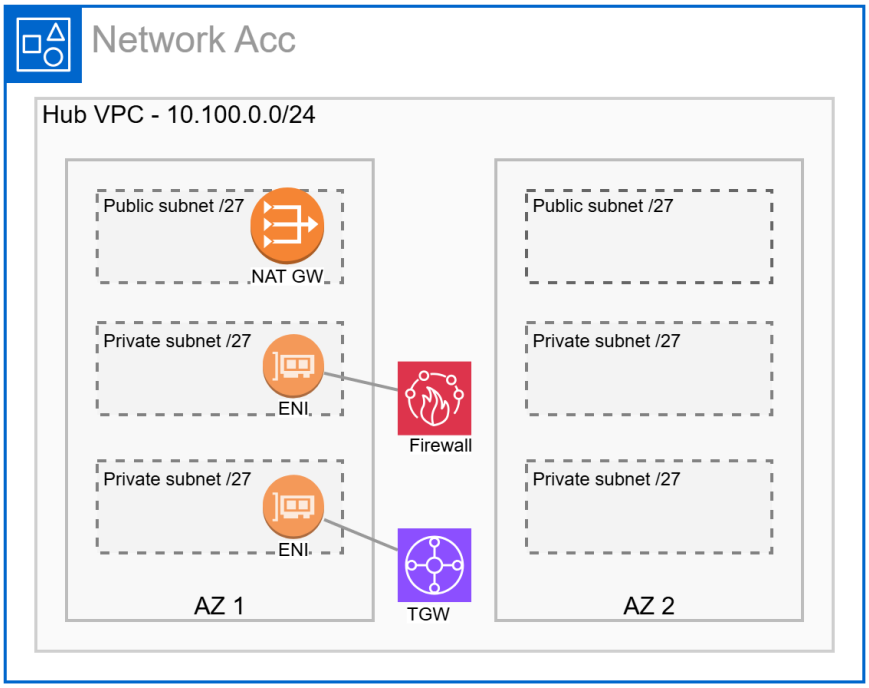


Figure 7 Hub VPC baseline deployment

The figure below illustrates how over time, with increased traffic volumes, the Hub VPC may evolve to span multiple AZs and therefore increase the availability and resiliency of network services.

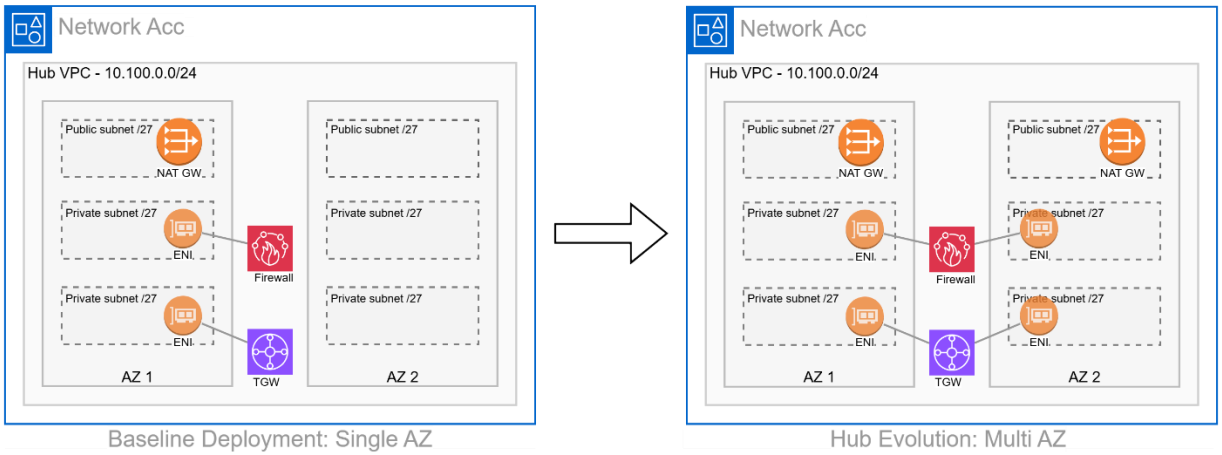


Figure 8 Hub VPC Evolution

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

4.7. Egress Design

As detailed, the Hub VPC will serve as a central point for controlling and inspecting all egress traffic.

The following list captures the network architecture specifically related to the egress design

- Rather than each spoke VPC having its own egress path (e.g., individual NAT Gateways and Internet Gateways), Spoke VPC route tables will direct all internet-bound traffic (0.0.0.0/0) to the Transit Gateway, ensuring all egress flows through a dedicated Hub VPC in the Network account, which acts as the sole internet egress point and control plane
- An AWS Transit Gateway instance deployed to the Network account acts as a central router. Spoke VPCs attach to the Transit Gateway, and the Transit Gateway routes their internet-bound traffic to the Hub VPC.
- The Transit Gateway "Appliance Mode" will be enabled for the attachment to the Hub VPC to ensure symmetric routing, which is crucial for stateful firewalls e.g. AWS Network Firewall, to maintain connection state.
- Egress internet bound traffic will traverse a security inspection layer (AWS Network Firewall) before reaching the internet via the NAT Gateway, ensuring comprehensive traffic filtering and threat detection.
- All internet-bound traffic from Spoke VPCs will exit through the static public IP address(es) of the centralised NAT Gateway (deployed to the Network account), providing a consistent and auditable source for external services.
- All relevant logs (Firewall, NAT Gateway, VPC Flow Logs from Hub) will be aggregated to the central logging account – Log Archive account - for comprehensive egress traffic visibility.

4.8. Ingress Design

The Landing Zone environment will adopt a decentralised/distributed ingress architecture to ensure optimal performance, security, and operational autonomy for individual workloads.

- Each backend workload and application will be responsible for creating and managing its own dedicated ingress infrastructure required to expose its web application frontend or API. This ensures tight coupling of ingress resources to the application stack, aligning with the principle of distributed ownership. This principle also aligns with the current configuration of the Bridge stacks.
- Individual workloads will utilise the most suitable AWS ingress service for their specific needs, such as:
    - Amazon CloudFront Distributions for web applications with a globally distributed user base. This common reference architecture will be supported by direct CloudFront-to-S3 origin configurations.
    - Application Load Balancers (ALBs) for more complex web applications or APIs requiring Layer 7 routing.
    - Amazon API Gateway for RESTful or WebSocket APIs.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

- As a core security guardrail within the AWS Landing Zone, all deployed Application Load Balancers (ALBs) and CloudFront Distributions must have an AWS WAF Access Control List (ACL) configured and associated. Resources deployed without a WAF will be flagged as non-compliant by the Landing Zone guardrails. This ensures comprehensive protection against common web exploits and malicious traffic.
- All internet-accessible workloads will be deployed within private subnets, with public subnets reserved exclusively for load balancing (e.g., ALBs, CloudFront Distributions). This pattern ensures that application instances are not directly exposed to the internet, enhancing the overall security posture.
- While ingress is distributed, security configurations for AWS WAF will be centrally administered and maintained through AWS Firewall Manager. This provides consistent security policy enforcement across all accounts and ingress points.

The specific ingress resources required to support an application will be determined as workloads are onboarded to the Landing Zone. No ingress resources will be deployed as part of the Landing Zone build.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

4.9. Ingress & Egress Traffic Flows

The diagram below illustrates the indicative ingress and egress networking design for the target state. It is provided for reference only and includes existing environments (such as Bridge) to show how traffic flows could be represented within the wider AWS estate.

While these accounts are shown for contextual purposes, their existing networking configuration is out of scope for the initial Landing Zone deployment and will not be modified as part of implementing the new Landing Zone.

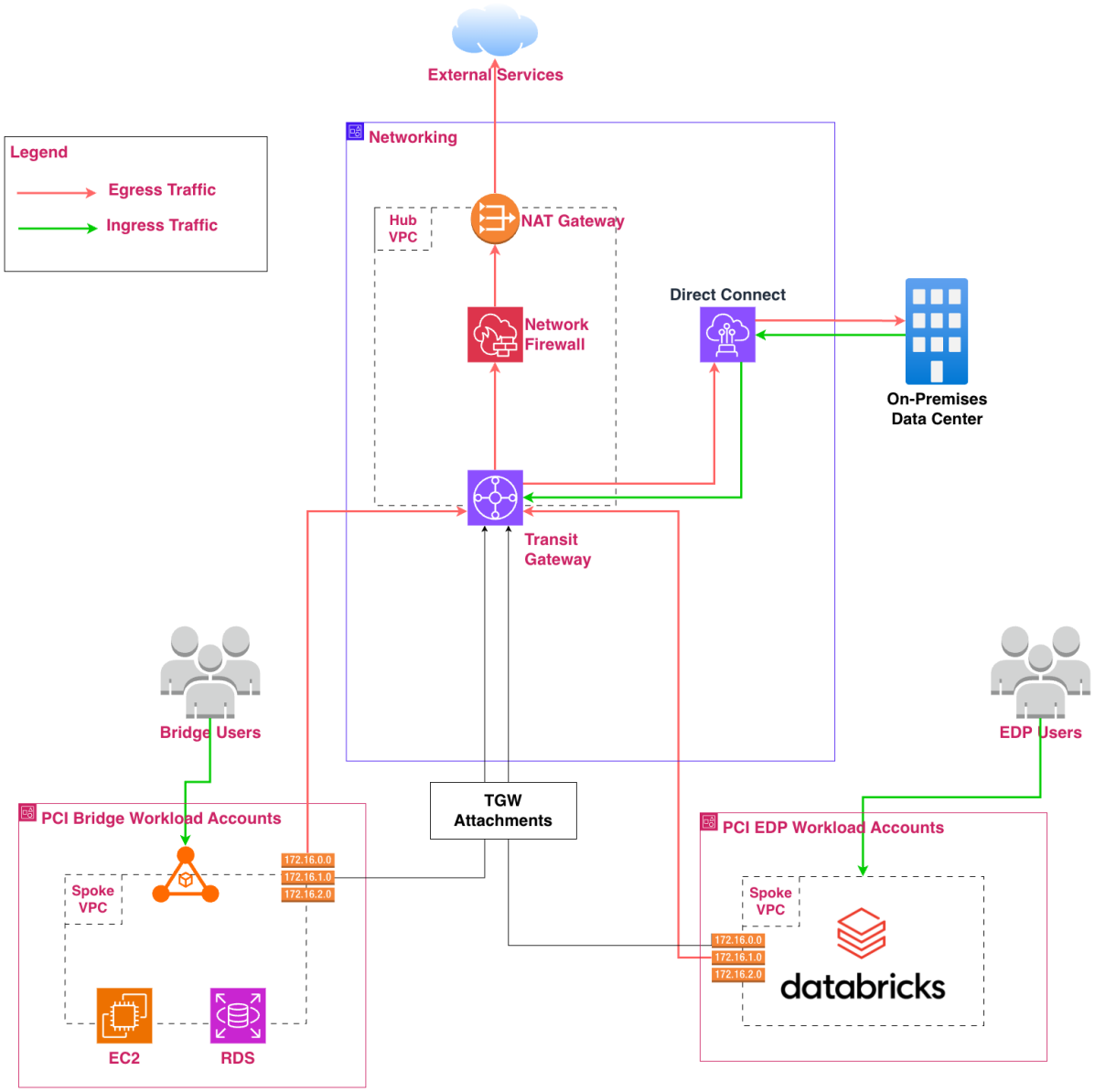


Figure 9 Ingress & Egress Traffic flows

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

4.10. Target-State Network Design Integrated with the Current Environment

This section describes how the proposed Landing Zone network design is integrated with the existing AWS environment while ensuring no impact to currently running services.

The target-state design introduces new, dedicated networking components for the Landing Zone, allowing it to operate independently from existing environments.

4.10.1. New Hub VPC in the Networking Account

A new Hub VPC will be created within the Networking account to support the Landing Zone network design.

This VPC is dedicated to the new Landing Zone and does not reuse or modify any existing VPCs currently supporting production workloads or shared services.

4.10.2. New Transit Gateway for the Landing Zone

A new Transit Gateway will be provisioned exclusively for the Landing Zone.

This approach ensures:

- No changes are required to existing Transit Gateway configurations
- Current environments (including Bridge) remain unaffected
- Routing and connectivity for the Landing Zone can be managed independently

The new Transit Gateway is introduced specifically to avoid any impact on services currently running in the environment.

4.10.3. Reuse of Existing Direct Connect Connections

The Landing Zone Transit Gateway will reuse the existing Direct Connect connections to provide connectivity between the Landing Zone and on-premises environments.

This design avoids the need for additional physical Direct Connect circuits and leverages the current connectivity already in place, subject to final routing and CIDR validation.

4.10.4. JDE DR Direct Connect Connectivity

Additional Direct Connect connections have been identified within the **JDE DR account**.

Further validation with the client is required to confirm:

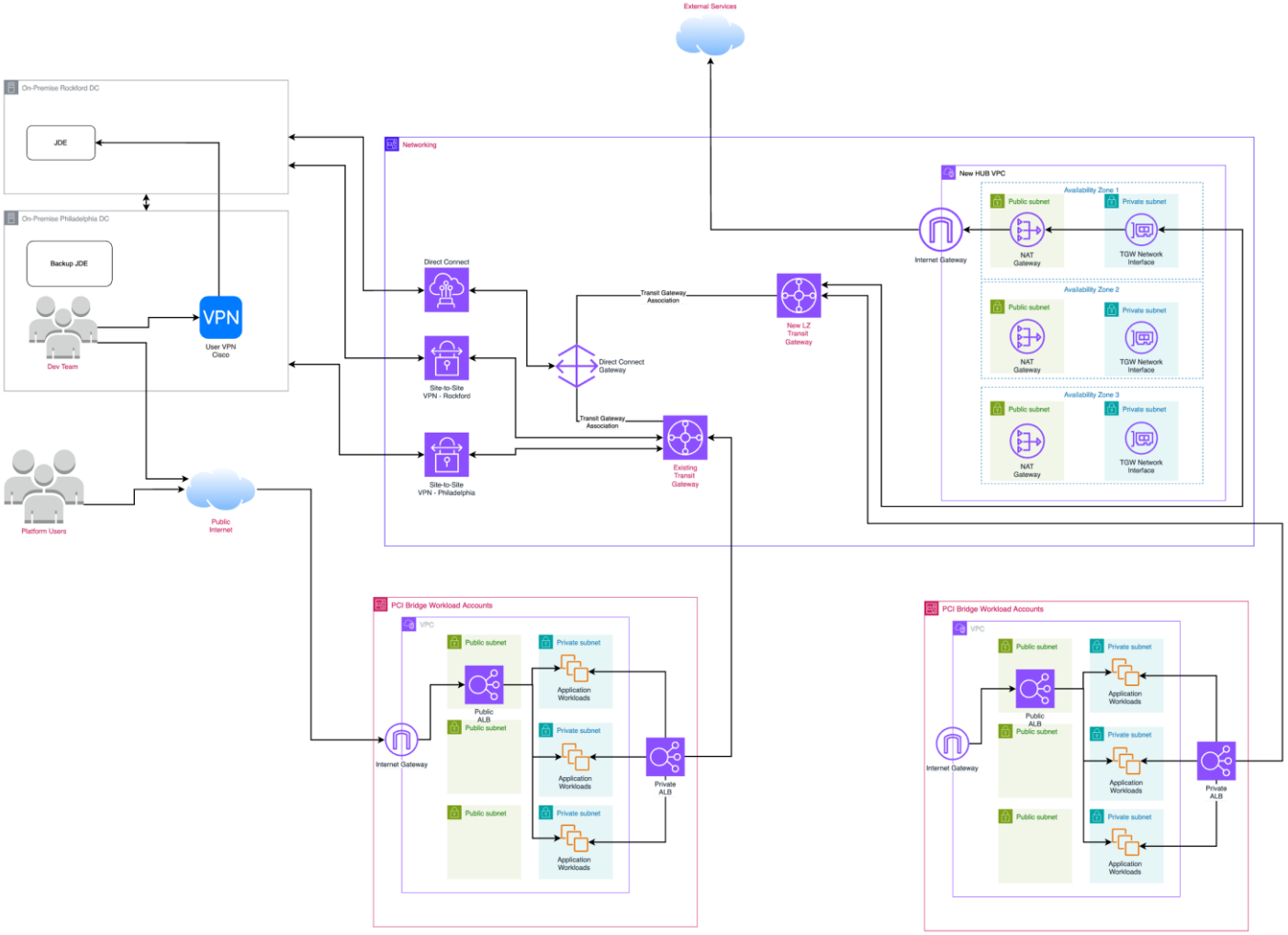
- Whether these connections are duplicated or serve JDE-specific requirements.
- Why JDE workloads are not consuming Direct Connect connectivity via the central Networking account.
- Whether these connections should be retained, consolidated, or excluded from the target-state design.

This remains an open point and will be addressed during the next design phase in collaboration with the client.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

4.10.5. Reference Architecture Diagram



Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

5. SECURITY

5.1. IAM Identity Center

IAM Identity Center (formerly AWS Single Sign-On) will be leveraged to provide a streamlined and secure method for managing access across the multi-account AWS environment.

- The Landing Zone Accelerator creates an IAM Identity Center instance in the AWS Management account. This service facilitates Single-Sign On for all AWS users which is especially pertinent when working in a multi-account structure. The introduction of this service negates the need to create and manage separate IAM users in each individual account, significantly reducing administrative overhead.
- It facilitates a seamless Single Sign-On experience for all AWS users. Users log in once to a central user portal with their credentials and can then securely access all assigned AWS accounts and roles without re-authenticating.
- When new users are created an invitation process guides them through password setup and mandatory Multi-Factor Authentication (MFA) configuration. This ensures a standardised, secure, and automated onboarding experience. Conversely, centralised management simplifies rapid offboarding and access revocation.
- Access to AWS accounts is managed through Permission Sets. These define specific AWS IAM policies and permissions (e.g., Administrator Access, Read-Only, Developer Access) that are then assigned to users or groups. IAM Identity Center automatically provisions and manages corresponding IAM roles in each target AWS account, ensuring consistent application of the principle of least privilege across your organisation.
- The management of new identities, existing identities and associated permissions is all managed under IAM Identity Center console.

For the initial Landing Zone implementation, IAM Identity Center will be configured to provide Single Sign-On (SSO) capabilities across all member accounts within the AWS Organisation, with users managed directly within Identity Center's own directory. The primary purpose at this stage is to centralise user access and streamline login to AWS accounts. This baseline configuration does not include integration with external Identity Providers (IdP) or the development of custom IAM roles via Identity Center.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

5.1.1. SSO Login Page

The table below captures the SSO login page for accessing the various AWS accounts deployed as part of the Landing Zone.

Description	Link
PCI AWS LZ SSO Landing Page	https://d-90678dc630.awsapps.com/start

5.1.2. Root Identities

When a new AWS account is created, whether it's a standalone account or part of an AWS Organization, a unique root user identity tied to an email address is a mandatory requirement to complete the process. For PCI's AWS Landing Zone, all the core Platform AWS accounts will leverage the "plus addressing" feature of the Management account's email address. This strategy ensures that the root user email for every core Platform AWS account adheres to a consistent and easily identifiable naming convention: *<management_account_email>+<AWS_Account Name>@pci.com*.

For example, since the Management account's email is *pciawslz@pci.com*, the root user email associated with the Landing Zone's Network account is *pciawslz**+network**@pci.com*. Similarly, the root user email associated with the Log Archive AWS account is *pciawslz**+logarchive**@pci.com*.

During the assessment, two email domains were identified within the existing AWS environment: pci.com and pciservices.com. A consistent approach to root account email addressing should be agreed to ensure clarity, traceability, and alignment with organizational standards across all Landing Zone accounts.

This method offers several benefits for managing a multi-account AWS environment:

- All root user emails for various accounts route to a single, controlled inbox associated with the Management account. This simplifies monitoring and significantly reduces the administrative overhead of managing separate mailboxes for each account.
- By centralizing email reception, it becomes easier to secure the primary email inbox, thereby safeguarding the recovery mechanism for all root users across the organization. This reduces the attack surface compared to scattering root user emails across multiple, potentially less secure, individual mailboxes.
- In the event of a lost root user password or compromised credentials for any member account, the password reset emails are delivered to the designated Management account inbox, facilitating a quicker and more controlled recovery process.
- Having a consistent and predictable naming pattern for root user emails aids in auditing and tracking account ownership and communication.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

For all workload AWS accounts deployed within the Landing Zone, shared mailboxes are used for root user and account-level notifications to reduce reliance on personal email addresses and to support operational continuity.

At present, the Bridge project already makes use of several shared mailboxes, including master-aws-gbl@pci.com, master-aws-gbl+tools@pci.com, and master-aws-gbl+qa@pci.com. Further clarification is required to confirm whether master-aws-gbl@pci.com is intended to be Bridge-specific or can be safely reused across additional workloads and organisational accounts.

As part of the Landing Zone design, it is recommended to introduce a dedicated shared mailbox for AWS Organization–level administration (for example, pciawslz@pci.com). This mailbox would be used for the Management account and other platform-level accounts, providing clear demarcation between organisation governance and project-specific workload accounts, and reducing the risk associated with mailbox reuse across differing security and operational scopes.

For AWS accounts deployed via the Platform config repository e.g. Network account, Audit account:

- An SSO Identity is automatically generated for each account, except for the Audit and LogArchive accounts. These two accounts only have a root user email address; they do not get an SSO identity.

For all new workload AWS accounts onboarded into the Landing Zone, a dedicated root user email address is assigned at account creation, and the account is integrated with AWS IAM Identity Center for all day-to-day administrative and operational access:

- This approach minimizes the need for direct root user logins and aligns with AWS best practices by enforcing federated access via centrally managed permission sets, roles, and groups.
- The root user is retained solely for exceptional break-glass scenarios, while routine access is performed through IAM Identity Center. Where account provisioning is automated, these controls are applied consistently as part of the onboarding process to ensure standardization across all workload accounts.

AWS Account	Root User Identity	SSO Identity
Management	pciawslz@pci.com	pciawslz@pci.com
Audit	pciawslz+**audit**@pci.com	N/A
Log Archive	pciawslz+**logarchive**@pci.com	N/A
Network	pciawslz+**networking**@pci.com	pciawslz+**networking**@pci.com
Identity	pciawslz+**identity**@pci.com	pciawslz+**identity**@pci.com
AFT Management	pciawslz+**aft**@pci.com	pciawslz+**aft**@pci.com

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

5.1.3. Securing Root Identities

While the root user of each AWS account in the Landing Zone should be used sparingly, securing the root email address and its associated identity is crucial for maintaining the overall security posture and ensuring a recovery mechanism for the multi-account environment. This email address serves as the primary recovery point for the account's root user credentials, making its compromise a critical threat that could lead to unauthorised access and control over AWS resources.

To achieve robust security for these critical root email identities, a standard process should be rigorously followed for each new account provisioned within the Landing Zone:

1. **Accept invitation:** Upon account creation and its invitation to the AWS Organisation, the root user associated with the unique email must accept the invitation. This involves a first-time login to the AWS Management Console for that specific account e.g. pciawslz***+network***@pci.com
2. **Initial login:** After the initial login, the default or temporary password must be immediately changed to a strong, complex, and unique password. This new password should never be shared verbally or stored insecurely.
3. **Securely store password:** The new password for each account's root user must be stored securely in an enterprise-grade password manager.
4. **MFA:** Multiple MFA devices (e.g., multiple virtual MFA applications on different trusted individuals' phones) should be registered to each root user. This redundancy ensures that if one device is lost or inaccessible, there are still alternative authorised MFA devices to regain access.
5. **Shared Mailbox:** The use of "plus addressing" (e.g., pciawslz***+network***@pci.com) routes all root user emails to a designated, shared mailbox (i.e., pciawslz@pci.com). This centralises the receipt of critical notifications for all accounts.
6. **Forwarding Rules:** (Optional but recommended) To mitigate the risk of important emails being lost or unread in a shared mailbox that might not be frequently checked, configure automated forwarding rules. These rules should forward all incoming emails from the root email addresses to a distribution list of relevant administrators or integrate with a centralised alerting system (e.g., Microsoft Teams). This ensures that critical alerts are pushed to the relevant personnel's personal inboxes or collaborative channels, requiring no explicit action to "check" the shared mailbox and dramatically reducing the chance of missing vital communications.

5.2. AWS Web Application Firewall

The AWS Web Application Firewall (WAF) service operates at Layer 7 of the OSI model and will primarily be used to introduce a layer of security on publicly exposed ingress infrastructure e.g. CloudFront Distributions and Application Load Balancers.

The list below provides a non-exhaustive list of the service's key functions:

- pre-configured rule groups provided by AWS to protect against common threats e.g. OWASP Top 10 vulnerabilities (SQL injection, XSS, etc.), known bad IPs, common bot attacks, and specific vulnerability exploits.
- custom rules based on IP addresses, HTTP headers, HTTP body, URI strings, query strings, HTTP methods, and size constraints.
- regular expressions for more flexible pattern matching in requests.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

- managed rule group specifically designed to detect and block common and egregious bots (e.g., scanners, crawlers, spammers) while allowing legitimate ones.
- metrics and dashboards in Amazon CloudWatch for monitoring traffic patterns and blocked requests.

The initial Landing Zone implementation does not require the deployment of new CloudFront distributions or Application Load Balancers, as a distributed ingress architecture is in place. The Bridge application already implements AWS WAF associated with Application Load Balancers to provide Layer 7 protection for externally exposed services.

For future workloads onboarded into the Landing Zone (for example, EDP), the ingress architecture and the associated use of CloudFront, Application Load Balancers, and AWS WAF will be defined as part of the workload-specific solution design. This approach ensures that ingress patterns and security controls are aligned with the functional, security, and exposure requirements of each workload, rather than being enforced centrally at the Landing Zone level.

5.3. AWS Network Firewall

The AWS Network Firewall service operates at Layer 3 & 4 of the OSI model for stateless and stateful inspection based on IP addresses, ports, and protocols. It also has Layer 7 awareness by way of Fully Qualified Domain Name (FQDN) filtering and Server Name Indication (SNI) inspection within encrypted traffic. The service will be deployed to the centralised Hub VPC within the Network account to govern egress traffic only.

The list below provides a non-exhaustive list of the service's key functions:

- monitors the state of connections (TCP, UDP, ICMP) and makes decisions based on the entire flow, not just individual packets. This is crucial for allowing return traffic of an established connection.
- supports session-based filtering and anomaly detection.
- allows/blocks traffic to specific Fully Qualified Domain Names (FQDNs).
- deployed in the Hub VPC as a firewall endpoint in dedicated subnets per AZ.
- integrates seamlessly with AWS Transit Gateway for centralised inspection of traffic from multiple VPCs (egress and inter-VPC traffic).
- Metrics and dashboards available under Amazon CloudWatch

For the initial Landing Zone implementation, the AWS Network Firewall will be configured with a default deny-all egress policy. This proactive security posture will remain in effect until specific workload requirements necessitate the creation of explicit egress rules upon onboarding to a Spoke account/VPC, such as the Enterprise Data Platform.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

5.4. AWS Security Hub

Within the AWS Landing Zone, Security Hub plays a critical central role in establishing and maintaining a robust security posture:

- Aggregates security findings from various AWS security services e.g., GuardDuty, Config
- By default, Security Hub will automatically check the AWS Landing Zone environment against a set of security best practices, providing actionable insights into misconfigurations and potential vulnerabilities.
- Offers a comprehensive, high-level view of your security posture across all linked accounts in your AWS Organisation.
- Security Hub is configured in the Audit Account within the AWS Landing Zone's multi-account structure. This account serves as the delegated administrator for Security Hub within AWS Organisations.
- Security Hub is configured to aggregate security findings from all member accounts in the AWS Organisation into this central Audit Account. This provides security teams with a single pane of glass for all security-related events and compliance status across the entire enterprise.
- The service facilitates the configuration of many industries recognised frameworks (e.g., CIS Benchmark) which, once enabled, automatically checks if resources deployed by development teams in spoke accounts adhere to established security guardrails.
- Centralising the Security Hub to the Audit account reduces the operational burden on individual account owners allowing them to focus on core application development while security is enforced consistently from the Landing Zone's security foundation.

For the initial Landing Zone implementation, AWS Security Hub will be configured to automatically enable and aggregate findings from all newly provisioned member accounts within the AWS Organisation. The AWS Foundational Security Best Practices (FSBP) standard will be activated by default to provide continuous security posture monitoring from day one. Further security standards (e.g., CIS AWS Foundations Benchmark, PCI DSS), custom insights, and automated remediation actions will be progressively assessed and configured as workloads are onboarded, and specific compliance and operational security requirements evolve.

5.4.1. AWS Foundational Security Best Practices v1.0.0

Developed by AWS and industry professionals, the AWS Foundational Security Best Practices (FSBP) standard is a compilation of security best practices for organizations, regardless of organisation sector or size. It provides a set of controls that detect when AWS accounts and resources deviate from security best practices. It also provides prescriptive guidance about how to improve and maintain your organization's security posture.

In AWS Security Hub Cloud Security Posture Management (CSPM), the AWS Foundational Security Best Practices standard includes controls that continuously evaluate your AWS accounts and workloads and help you identify areas that deviate from security best practices. Further detail regarding the security controls introduced as part of this framework are detailed here.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

Following the Landing Zone implementation, PCI will need to adopt a process to continuously evaluate the Landing Zone's security posture score and develop a mechanism to address critical security notifications.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

6. TAGGING STRATEGY

A consistent tagging strategy is a foundational control in the Landing Zone to enable cost allocation (FinOps/showback/chargeback), operational ownership, security & compliance reporting, and automation across accounts and workloads. AWS recommends standardizing tag keys/values, applying tags consistently (ideally at creation), and governing compliance using tools such as Tag Editor/Resource Groups Tagging API, AWS Config rules, and AWS Organizations Tag Policies.

6.1. Recommended tags by AWS

The tags below are AWS's minimum suggested tags, plus some additional tags relevant to PCI's applications and workloads.

Technical tags	Tags for Automation	Business tags	Security tags
Name – Identify individual resources	**Date/Time** – Identify the date or time a resource should be started, stopped, deleted, or rotated	**Project** – Identify projects that the resource supports	**Confidentiality** – An identifier for the specific data confidentiality level a resource supports
Application ID – Identify resources that are related to a specific application	**Opt in/Opt out** – Indicate whether a resource should be included in an automated activity such as starting, stopping, or resizing instances	**Owner** – Identify who is responsible for the resource	**Compliance** – An identifier for workloads that must adhere to specific compliance requirements
Application Role – Describe the function of a particular resource (such as web server, message broker, database)	**Security** – Determine requirements, such as encryption or enabling of Amazon VPC flow logs; identify route tables or security groups that need extra scrutiny	**Cost Center/Business Unit** – Identify the cost center or business unit associated with a resource, typically for cost allocation and tracking	
Cluster – Identify resource farms that share a common configuration and perform a specific function for an application		**Customer** – Identify a specific client that a particular group of resources serves	
Environment – Distinguish between			

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

development, test, and production resources			
Version – Help distinguish between versions of resources or applications			

6.2. Tagging Enforcement

Tagging enforcement within the AWS Landing Zone defines how mandatory resource tags are standardised, governed, and applied across AWS accounts. The objective is to ensure consistent cost allocation, ownership visibility, and operational management while minimising disruption to existing workloads.

AWS provides several mechanisms to support tagging enforcement, each with a different level of strictness and operational impact.

- At the organization level, AWS Organizations Tag Policies are used to define required tag keys, approved values, and naming conventions. Tag Policies are non-blocking and do not prevent resource creation. They provide centralized visibility into tagging compliance and establish a common baseline that applies across selected Organizational Units.
- For new workloads, tagging is enforced through Infrastructure as Code (IaC). Terraform and CloudFormation templates require mandatory tags at deployment time, ensuring resources created via approved pipelines are compliant by default. This approach provides early enforcement without impacting manually created or legacy resources.
- Where stronger controls are required, Service Control Policies (SCPs) can be used to prevent the creation of resources without mandatory tags by denying create actions when required tags are missing. Due to limitations in tag-on-create support and the risk of impacting automation or AWS-managed services, SCP-based enforcement is applied selectively, typically only in production or mature Organizational Units.

In addition, detective controls provide continuous visibility into tagging compliance and support remediation over time without blocking deployments.

The planned approach is to apply tagging enforcement progressively:

1. Define organisation-wide tagging standards using non-blocking controls.
2. Enforce mandatory tags through delivery pipelines for new resources.
3. Monitor compliance and remediate gaps.
4. Introduce preventative enforcement only where operational risk is low.

This phased model ensures consistent tagging across the Landing Zone while supporting a controlled and low-risk adoption.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

6.3. Mandatory and Recommended Tagging Model

To support consistent cost allocation, ownership visibility, operational management, and compliance reporting across the Landing Zone, a standardised tagging model is proposed based on AWS best practices.

Tags are categorised as Mandatory or Recommended, with clearly defined purposes and controlled value sets where appropriate. The final tag set, naming conventions, and allowed values will be validated and agreed with PCI prior to enforcement.

6.3.1. Mandatory Tags

Mandatory tags are required on all in-scope resources created within the Landing Zone. These tags form the minimum baseline for cost management, ownership, and governance.

Tag Key	Description	Expected Values
Project	Identifies the project the resource supports	Bridge, JDE, EDP
Environment	Identifies the deployment environment	Prod, NonProd, Dev, Test
Owner	Logical owner or team responsible for the resource	Team name or distribution group
CostCenter	Cost center or business unit for financial tracking	PCI-defined values
ApplicationID	Identifier for the application or workload	App code or agreed identifier

6.3.2. Recommended Tags

Tag Key	Description	Expected Values
Name	Human-readable resource identifier	edp-api-alb-01
ApplicationRole	Functional role of the resource	web, database, queue
Version	Application or resource version	v1.2.0
Cluster	Logical grouping of related resources	edp-ecs-cluster
Confidentiality	Data classification level	Public, Internal, Confidential
Compliance	Regulatory or compliance scope	PCI, GDPR, None

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

6.3.3. Tag Standardisation, Scope, and Governance

To maximise the effectiveness of the tagging strategy, AWS recommends standardising tag keys and values wherever tags are used for cost allocation, reporting, automation, or compliance.

As part of the Landing Zone design:

- Controlled value sets will be defined for key tags such as Project, Environment, and Compliance to ensure consistent reporting and avoid free-text inconsistencies.
- The tagging model will apply to all new accounts and resources provisioned via the Landing Zone, while existing workloads remain out of scope for retroactive enforcement unless explicitly agreed.
- Tagging standards, required tags, and allowed values will be defined and validated in collaboration with PCI to ensure alignment with organisational structures, financial processes, and governance requirements.

Tagging compliance will be implemented progressively, prioritising non-blocking controls and automation-based enforcement, in line with AWS best practices, to minimise operational risk while establishing a consistent baseline across the Landing Zone.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

7. COST MANAGEMENT

7.1. Consolidated Billing

PCI already operates under AWS Organizations consolidated billing, where the AWS Management account is responsible for consolidating and settling charges incurred by all member accounts. The proposed Landing Zone does not introduce any changes to the existing billing model; instead, it continues to leverage this capability as a foundational organisational control.

Under consolidated billing, AWS charges from all member accounts are aggregated at the organisation level, providing a single bill per Statement of Record (SOR). This enables consolidated visibility of costs across accounts, while still allowing charges to be analysed and reported at an individual account level using cost and usage reports.

The organisation benefits from combined usage aggregation, allowing workloads to share volume-based pricing discounts, including Reserved Instances and Savings Plans, which can result in lower overall costs compared to standalone accounts. Consolidated billing is provided by AWS at no additional cost.

As part of the Landing Zone, existing cost management capabilities can be extended or standardised, including:

- AWS Budgets to define account or project-level cost thresholds and alerts.
- Cost and usage reporting to support chargeback or showback models.
- Cost anomaly detection and alerts to improve financial governance and early identification of unexpected spend.

These capabilities support improved financial visibility and control across workload and platform accounts, without altering PCI's current consolidated billing approach.

7.2. Cost Governance, Budgets and Alerts Approach

As PCI currently operates multiple projects within the AWS organisation (including Bridge and JDE, with an additional EDP project planned), a structured and consistent approach to cost governance is recommended to ensure ongoing financial visibility and control as the environment scales.

As part of the Landing Zone adoption, it is recommended that AWS cost management controls are standardised and aligned with the project and organisational structure, while remaining fully aligned with PCI's existing consolidated billing model.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

The following approach is proposed, subject to validation and agreement with PCI:

- **Organisation-level budgets**: High-level budgets defined at the organisation or Statement of Record (SOR) level to provide executive visibility of total AWS spend and forecasted costs.
- **Project-level budgets (Bridge, EDP, and future projects):** Budgets aligned to individual projects, using a combination of account-level budgets and/or cost allocation tags, to enable clear separation of spend and support chargeback or showback models.
- **Account-level budgets for new Landing Zone accounts:** Standardised budgets applied to all newly provisioned accounts within the Landing Zone, providing early warning of unexpected cost growth and supporting consistent financial governance.
- **Threshold-based alerts:** Budgets configured with multiple alert thresholds (e.g. percentage-based alerts for actual and forecasted spend) to provide progressive visibility rather than reactive notification.
- **Centralised alerting and notification:** Budget and anomaly alerts integrated with centrally managed notification channels (such as shared email distribution lists), avoiding reliance on individual user notifications.
- **Cost Anomaly Detection as a complementary control:** AWS Cost Anomaly Detection used in conjunction with AWS Budgets to identify unusual spending patterns or unexpected spikes, particularly during periods of onboarding new accounts or workloads.

All budgets, thresholds, alerting mechanisms, and tagging standards will be defined and agreed in collaboration with PCI to ensure they align with existing financial processes, reporting requirements, and governance expectations. This approach enables improved cost visibility and proactive financial control without introducing changes to the underlying consolidated billing model.

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

8. ESTIMATED COSTS FOR LANDING ZONE RESOURCES

The following cost estimation is based on the AWS billing data from December 2025, reflecting the current steady-state consumption of shared and foundational AWS services across the existing environment. The estimated monthly costs represent the expected incremental impact of introducing an AWS Landing Zone, using AWS reference pricing and Landing Zone Accelerator cost assumptions for baseline governance, security, logging, and networking services.

This estimation focuses exclusively on platform and shared services required to operate the Landing Zone, such as centralized networking, security, logging, monitoring, and governance capabilities. Project-specific workloads and resources associated with the EDP project are explicitly excluded from this analysis. As additional workload accounts and application resources are onboarded in future phases, further cost increases should be expected and assessed separately.

The figures provided are intended to offer a directional and conservative estimate to support high-level planning and decision-making, rather than a detailed, workload-level cost forecast.

AWS Service	Current Monthly Cost [USD]	Estimate Monthly Cost [USD]
AWS CloudTrail	24.83	50
AWS Config	68.83	92
AWS KMS	32.73	50
Amazon Kinesis	0	10
Amazon Data Firehose	0	5
Amazon VPC	1220.87	1500
Amazon CloudWatch	31.76	50
AWS Security Hub	112.38	150
Amazon GuardDuty	565.05	600
Amazon Route 53	192.56	360
Amazon Macie	0	10
AWS Secrets Manager	19.79	22
AWS CodePipeline	0	1
AWS CodeBuild	0	6
AWS Network Firewall	0	350
Total	**$2269**	**$3256**

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled

Thank you

For more information,
please visit version1.com

Copyright ©2025 Version 1. All rights reserved.

Classification: Controlled